

PacketLens

PCAP Network Analysis Report Tool — User Guide

Version 3.4.1 · Analyzer 3.4.0 · Report schema 1.0 · Risk specification 1.3
Web application (self-hosted Next.js server)

Contents

1. What is PacketLens?
2. Quick Start
3. Analyzing a Capture
4. The Analysis Report
5. Exporting Results (PDF / HTML / CSV)
6. Interactive Tools (Graph, World Map, Visualizations)
7. Detection & Risk Model
8. GeolP & Vendor Attribution
9. Settings
10. Self-Hosting & Deployment
11. Security Notes
12. Requirements

1. What is PacketLens?

PacketLens is a network security analysis tool that turns a raw packet capture (PCAP / PCAPNG) into a professional, exportable security report. Upload a capture file — or open the built-in demo dataset — and PacketLens parses the traffic on the server, then produces a 23-section report covering traffic summary, packets, flows, sessions, DNS, HTTP, TLS, notable destinations, extracted payloads, VoIP calls, credential submissions, certificates, endpoints, timeline, top talkers, threats and alerts, a numerical risk score, findings, MITRE ATT&CK mappings, prioritized recommendations, an appendix, and an analyst conclusion.

PacketLens is a single web application: one Next.js server that serves the interface, accepts uploads, runs the analysis, and serves the results back to your browser. There is no separate desktop app and no separate analysis engine to deploy — the capture file is processed entirely by the server you run.

2. Quick Start

2.1 Running the app

1. Install Node.js 20 or newer.
2. Run `npm install` inside the `frontend/` directory.
3. Development: run `start-dev.bat` (Or `npx next dev --port 3456`) and open <http://localhost:3456>.
4. Production: `npm run build` , then `npm start` (see section 10).

2.2 First steps

1. Click **Live Demo** on the landing page to explore every feature with a realistic pre-loaded dataset — no capture file needed.
2. Or drop a PCAP / PCAPNG file onto the upload zone.
3. The analysis opens automatically when parsing finishes. Bookmark the job URL to return to the same analysis later.

3. Analyzing a Capture

- **Upload a file** — PCAP and PCAPNG formats, up to 500 MB. Uploads are rate-limited (5 per minute per address) and rejected from other origins. While analysis runs, a progress screen shows the decode rate and current stage.
- **Demo dataset** — a realistic capture with benign + malicious traffic, pre-loaded with analysis, so every feature can be explored without a capture file. Demo analyses are labelled as such in the report.
- **Duplicate frames** — consecutive duplicate frames (capture artifacts) are removed before analysis. Every metric, detection and risk score is computed on the analyzed set, so duplicate frames never inflate flows, SYN counts or rates. The report states raw frames, removed duplicates, and analyzed counts alongside a capture-quality grade.
- **App-layer visibility** — shown as a separate dimension from capture quality: a clean dedupe rate does not mean packet content could be inspected. Mostly-encrypted captures state their visibility limit

explicitly; a 0% payload-visibility capture never reads as content-verified.

- **Encapsulation** — Ethernet is fully supported. Unsupported link types (e.g. raw IP) still produce packet lengths and timestamps; the report clearly states the decode rate and withholds a verdict when too little traffic was decodable (it reads UNKNOWN / INSUFFICIENT DATA rather than a false "clean" score). An explicit link-layer override can be set before uploading for captures whose headers were not auto-detected.
- **History** — completed analyses are stored on the server in `~/.packetlens/jobs.json`; the 20 most recent are kept, with the oldest evicted automatically. A bookmark to the job URL reloads the full analysis.

The capture file is processed on the server hosting this deployment, never in your browser. It is held in memory during the request and is not written to disk; only the finished analysis result is persisted (see the Privacy Policy).

4. The Analysis Report

Every analysis produces one canonical report with 23 numbered sections:

- | | |
|-----------------------------|--------------------------------------|
| 1. Executive Summary | 12. Credential Submissions |
| 2. Traffic Summary | 13. Certificates |
| 3. Packets | 14. Endpoints |
| 4. Flows | 15. Threats & Alerts |
| 5. Sessions | 16. Timeline |
| 6. DNS Analysis | 17. Top Talkers |
| 7. HTTP Analysis | 18. Risk Score (incl. Traffic Burst) |
| 8. TLS Analysis | 19. Findings & Observed Sources |
| 9. Notable Destinations | 20. MITRE ATT&CK Mapping |
| 10. Extracted HTTP Payloads | 21. Recommendations |
| 11. VoIP / SIP Calls | 22. Appendix |
| | 23. Analyst Conclusion |

Sections cover packet counts, flows, sessions, local devices, DNS lookups (deduplicated through the LAN resolver), plaintext HTTP requests (requests and headers decoded, message bodies/payloads extracted), TLS handshakes and certificate chains, files reconstructed from HTTP traffic, per-destination country distribution via the installed GeoIP database, credentials spotted in cleartext auth traffic (masked by default, revealable per entry), VoIP calls with RTP statistics, TCP health (handshake RTT, retransmissions, out-of-order, zero-window, RST, loss computed against data-segment denominators), and a per-interval activity timeline.

Findings & Observed Sources (section 19) separates three classes so they can never be confused: *Confirmed exposures* (e.g. a plaintext credential submission — the affected host is the victim of the exposure, not a malicious artifact), *Behavioral anomalies* (suspected traffic-pattern findings such as large outbound transfers or beaconing, each prefixed "Observed source: src → dst" — observed behavior, never an established incident), and *Indicators / IOCs*.

The summary cards show the **Risk Score** (0–100), the **Risk band** (the score's own numeric band, e.g. MEDIUM) and the **Highest Finding** severity (1–5) side by side, so a report is never read as Critical just because a suspected rule carries a high severity while its band is lower. A **Beginner / Expert** toggle adjusts how much detail the report shows.

5. Exporting Results

From the report page, three export formats are available:

Format	What you get	Best for
PDF	The full report via your browser's print dialog: cover page with file metadata and a demo/live marker, all 23 sections, print-optimized tables that avoid page-break splitting.	Sharing with stakeholders, evidence files.
HTML	A standalone, self-contained HTML file with the full summary, tables, and a deep link back to the live report in PacketLens. Works offline, styled for reading.	Email attachments, archiving, viewing in any browser.
CSV	One row per network flow: IPs and ports as separate columns (IPv6-safe), sent/recv bytes, timing, duration, geo country/ASN per endpoint, service name, RTT, retransmissions, loss. UTF-8 BOM included so Excel/Sheets decode vendor names correctly.	SIEM ingestion, pandas/Excel pivot analysis.

6. Interactive Tools

6.1 Investigation Graph

A cytoscape-based graph of the capture's communication: local devices and remote endpoints as nodes, conversations as edges. Click a node to see its traffic, drag to rearrange, zoom, and filter. Useful for spotting star-pattern C2 or broadcast storms at a glance. Layout and display preferences persist in your browser.

6.2 World Map

A geographic view plotting every remote endpoint by country with arcs representing traffic flows, animated to show conversation volume, and alert markers for flagged hosts. Pins are sized by traffic volume; nearby endpoints cluster into city-level bubbles. Works without the GeoIP database — it simply degrades to "no location data" notes. Without a home location the map anchors arcs at a synthetic point; set Home in Settings for exact lines.

6.3 Visualizations

A dedicated dashboard of traffic charts: protocol distribution, bandwidth over time, top talkers, packet rates and timeline heatmaps. The verdict shown on the visualizations page follows the same confirmed-findings rule as the report (a suspected critical rule is never presented as a confirmed Critical).

7. Detection & Risk Model

- **Signature rules** — port scanning, SYN floods, DNS tunneling, credential leaks, malware downloads, C2 beaconing, data exfiltration, suspicious TLS, and cleartext HTTP credentials. Each alert carries severity, confidence, source/destination, status (confirmed or suspected), and evidence naming the exact triggering conversation.

- **Exfiltration honesty** — the byte-ratio exfil rule (DATA-EXFIL-001) is directional behavior only: its evidence states "payload visibility: X of Y packets inspected — exfiltration content: NOT CONFIRMED", names the upload type (encrypted cloud/media uploads are called out as legitimate patterns), and evaluates thresholds on unique TCP payload bytes so retransmissions never inflate the ratio. NAT-traversal and discovery protocols (STUN/TURN, ports 3478/3479/5349/19302/5004/5005, DNS, DHCP, NTP, mDNS, LLMNR, SSDP, SIP, multicast/broadcast) never fire the rule. Severity is a ladder: Medium by default, High when the flow's protocol is payload-verified, Critical only when a confirmed credential exposure corroborates the same capture.
- **Honest verdicts** — the verdict level floors only on CONFIRMED findings; with no confirmed findings there is no floor, so a suspected Critical rule is stated separately and never headlines the report as Critical. Captures whose encapsulation prevented header decoding read UNKNOWN / INSUFFICIENT DATA instead of a false "clean" score, and single-packet captures without a measurable time interval also conclude insufficient evidence.
- **Risk score** — a single 0–100 score computed from a transparent formula ($100 \times (1 - e^{(-raw/80)})$): each alert contributes (severity weight + rule weight) $\times$ a confidence multiplier, with burst detection able to boost eligible rules. The report shows the full breakdown per rule and always states the spec version used.
- **IOCs & MITRE** — every finding is classified (IP, domain, URL, certificate...) and mapped to MITRE ATT&CK techniques (T1046, T1071, T1041, T1552, etc.) with the source labeled as confirmed alert or behavioral indicator. Threshold-level findings and exposure-style findings are deliberately unmapped unless the evidence demonstrates the technique was executed.

8. GeoIP & Vendor Attribution

- **GeoIP database** — the first time a capture needs country attribution, the server downloads the free DB-IP City Lite database (≈ 125 MB, CC BY 4.0) once and stores it in `~/.packetlens/geo/`. The install is single-flight: concurrent requests share one download.
- **Custom database** — you can instead upload your own MaxMind-format MMDB file via Settings → GeoIP Database; the uploaded file replaces the auto-installed one. Remove it anytime with the Remove button (auto-install resumes on the next analysis).
- **Online lookups (optional)** — Online GeoIP Lookups is disabled by default. When enabled, only IP addresses missing from the local database are resolved via the ipwho.is service; nothing else is sent.
- **Vendor lookup** — MAC-address vendors come from the bundled OUI registry (`oui.json`) and never require a network call. Raw-IP captures without Ethernet headers have no MACs, so vendor lookup reports "no MAC addresses" instead of a fake 0.

9. Settings

Setting	What it does
Beginner Mode	Simplifies labels and masks IP addresses in the graph view.
Link-layer override	Forces a DLT (e.g. Ethernet, Raw IP, Linux SLL) when the capture's encapsulation is not auto-detected.
Manual Home Location	Lat/lon used to anchor the world map's local arcs. Stored in your browser only.
Online GeolIP Lookups	Opt-in ipwho.is resolution for IPs missing from the local database (off by default).
GeolIP Database	Shows install status, installs/removes the DB-IP database, and accepts an uploaded MMDB file.
Danger Zone → Clear Analysis	Discards the currently loaded analysis from the session. Server-side job retention is bounded by the 20-job cap described in section 3.

10. Self-Hosting & Deployment

PacketLens is a standard Next.js application (`output: "standalone"`):

1. `npm run build` inside `frontend/`, then `npm start` — the server listens on the configured port.
2. Persistent data lives in `~/.packetlens/` (analysis history `jobs.json`, GeolIP database `geo/`). Mount a persistent volume there (or set `HOME`) so jobs and the database survive restarts.
3. Memory: an upload is fully buffered and analyzed in-process (500 MB cap), so concurrent uploads need roughly 1.5–2.5 GB each. Size the instance accordingly (4 GB RAM is comfortable).
4. Behind a reverse proxy, forward the client address (e.g. `X-Real-IP`) so the upload rate limit keys on real clients. TLS terminates at the proxy; the app already emits HSTS and CSP headers.

PacketLens is designed as a single instance: analysis history and rate limiting live in one process. Horizontal scaling would require externalizing the job store and rate limiter.

11. Security Notes

- Uploads are restricted to .pcap/.pcapng, capped at 500 MB (checked against Content-Length before the body is buffered), rate-limited per client address, and rejected from cross-origin callers.
- File names are sanitized before storage; analysis jobs are kept under a 0700 directory with 0600 file permissions.
- The app emits a restrictive Content-Security-Policy, HSTS, X-Frame-Options DENY, and nosniff headers. No third-party analytics or telemetry are embedded.
- Captures are a privacy-sensitive artifact: they are processed only on the server you run and are never written to disk. Report data (credentials, certificates, extracted files) is displayed in the app; exporting it

deliberately is your choice as the analyst.

- GeolIP and OUI vendor data are open-data (DB-IP Lite CC BY 4.0 / OUI registry) and are only used for attribution labels.

12. Requirements

Item	Requirement
Server	Node.js 20+, ~2 GB free memory (4 GB recommended for concurrent uploads), disk for <code>~/.packetlens</code> (GeolIP database $\approx$ 125 MB)
Browsers	Chrome, Edge, Firefox, Safari (recent versions)
Network (server)	Outbound HTTPS for the optional one-time GeolIP database download and the opt-in ipwho.is lookups

PacketLens 3.4.1 · Analyzer 3.4.0 · Report schema 1.0 · Risk spec 1.3 · Detection engine: signature rules + behavioral metrics ·
Open-data GeolIP: DB-IP City Lite (CC BY 4.0)